

```

--
=====
=====
-- SECTION: TABLE & ROUTINE GRANTS (anon /
authenticated / service_role)
--
=====
=====

-- ----- TABLE-LEVEL GRANTS -----
-- 99 of 100 relations (96 tables + 4 views) follow
Supabase's standard
-- default: anon, authenticated, and service_role
all hold full
--
DELETE/INSERT/REFERENCES/SELECT/TRIGGER/TRUNCATE/UP
DATE at the GRANT
-- level. This is NORMAL and NOT a misconfiguration
-- Supabase grants
-- broadly at the schema/role level by design, and
RLS (file 07) is the
-- real access-control layer that restricts what
anon/authenticated can
-- actually see or touch row-by-row.
--
-- The exception: the 4 introspection views do NOT
grant SELECT to
-- `anon` (only to `authenticated`/`service_role`):
--   payment_reconciliation_summary,
--   rls_enforcement_status,
--   schema_contract, security_advisory_summary
-- These are diagnostic/audit views (they expose
schema metadata and a
-- payment/order drift comparison) -- correctly not
readable by
-- unauthenticated clients.

```

```

GRANT ALL ON ALL TABLES IN SCHEMA public TO anon,
authenticated, service_role;
REVOKE SELECT ON
public.payment_reconciliation_summary FROM anon;
REVOKE SELECT ON public.rls_enforcement_status FROM
anon;
REVOKE SELECT ON public.schema_contract FROM anon;
REVOKE SELECT ON public.security_advisory_summary
FROM anon;

-- ----- FUNCTION EXECUTE GRANTS -----
-- This is the security-relevant list: which roles
can directly invoke
-- which RPCs. Everything NOT listed for
anon/authenticated below is
-- service_role-only, meaning it can only be called
from your Python
-- backend using the service key -- never directly
from a client.

-- anon + authenticated can call (client-callable
RPCs):
GRANT EXECUTE ON FUNCTION public.claim_guest_order
TO anon, authenticated;
GRANT EXECUTE ON FUNCTION
public.hg_create_order_atomic TO anon,
authenticated;
GRANT EXECUTE ON FUNCTION
public.hg_credit_delivery_hp_atomic TO anon,
authenticated;
GRANT EXECUTE ON FUNCTION
public.hg_credit_referral_milestone_atomic TO anon,
authenticated;
GRANT EXECUTE ON FUNCTION public.hg_place_order TO
anon, authenticated;
GRANT EXECUTE ON FUNCTION
public.hg_extract_storage_path TO anon,
authenticated;
GRANT EXECUTE ON FUNCTION

```

```

public.increment_monthly_hp_tracker TO anon,
authenticated;

-- authenticated only:
GRANT EXECUTE ON FUNCTION
public.get_menu_item_review_stats TO authenticated;
GRANT EXECUTE ON FUNCTION
public.hg_current_user_role TO authenticated;
GRANT EXECUTE ON FUNCTION public.hg_is_admin TO
authenticated;

-- Everything else (debit_wallet_atomic,
credit_wallet_atomic,
-- hg_add_hp_transaction,
hg_add_wallet_transaction, hg_mark_order_paid,
-- hg_redeem_reward, hg_purchase_marketplace_item,
-- hg_process_referral_reward,
hg_run_hp_expiry_check,
-- hg_run_tier_maintenance_check,
hg_anonymize_user,
-- hg_verify_wallet_conservation_invariant, all
hg_on_*/trigger
-- functions, etc.) grants EXECUTE to service_role
only -- confirmed no
-- anon/authenticated grant exists on any of these.
This means the
-- money-moving and HP-ledger primitives cannot be
invoked directly by
-- a client; they can only run via a trigger, a
service-role-authenticated
-- Python backend call, or from inside another
SECURITY DEFINER function
-- that itself is client-callable (see
12_function_dependencies.md for
-- exactly which client-callable functions
internally call these).

```